



RESPONSE TO: AGENTIC AI GOVERNANCE

Governance of Agentic AI Systems

How we design, implement, and operate autonomous agents that are safe, secure, and within organizational, ethical, and regulatory boundaries — while delivering value.

NIST AI RMF

ISO/IEC 42001

HIPAA

HITRUST

SOC 2 Type II

EU AI Act (risk-tiering)

For autonomous agents operating in an enterprise healthcare environment, governance cannot be a policy document that sits *beside* the system — it must be the operating fabric the system runs *on*. Our governing principle is **bounded autonomy**: an agent may act independently only within boundaries that are explicitly defined, **technically enforced at runtime**, continuously monitored, and fully auditable — and a **named, accountable human owns every decision that carries clinical, financial, or regulatory consequence**. Our framework is built to, and independently assessed against, recognized standards — NIST AI RMF, ISO/IEC 42001, HIPAA, HITRUST, and SOC 2 Type II — and risk-tiers agent use cases consistent with the EU AI Act. The objective is not to constrain AI in order to manage risk; it is to make the *expansion* of autonomy a controlled, evidence-based decision.

1 Governance operating model & accountability

An **AI Governance Council** — spanning clinical, privacy/compliance, security, legal, data, and business ownership — sets policy and risk appetite and authorizes every production deployment, operating on a three-lines-of-defense model. Each agent is entered in a central **agent registry** capturing its purpose, scope, owner, risk tier, data access, dependencies, and approval history. Every agent carries a clear **RACI** (business owner, agent-performance manager, security, compliance) and progresses through **stage-gate approvals** before it touches production traffic.

2 Bounded autonomy — defining and constraining behavior

Each agent is granted an explicit, **least-privilege operating scope**: the actions it may take, the systems it may reach, the data it may see, and the thresholds at which it must hand off. These constraints are enforced as **policy-as-code guardrails at runtime** — action allow-lists, input/output filtering, rate and spend limits — not merely described in a prompt. **Consequential actions require human approval gates**, and autonomy is **tiered by risk**: low-risk, reversible actions run unattended, while high-impact or irreversible actions are gated to a human. Agents act under **scoped, revocable non-human identities** — never shared human credentials.

3 Safety & reliability

Agents are engineered to **fail safe**. Layered controls combine **uncertainty/confidence gating** (the agent escalates rather than guesses), grounding and validation against authoritative sources, and deterministic checks for anything that must be exact. Before production, every agent is validated through **scenario-based evaluations and adversarial red-teaming** — including prompt-injection and tool-misuse testing. At runtime, **circuit breakers, rate limits, and an instant kill-switch** allow an agent to be suspended immediately. The default behavior under ambiguity is always to stop and route to a qualified human.

4 Security & data protection

Agents deploy **within the client’s security perimeter and data-residency posture**; PHI is handled under existing HIPAA controls, BAAs, encryption in transit and at rest, and least-privilege access — adding **no new uncontrolled data egress**. Our threat model explicitly addresses **agent-specific risks** — prompt injection, data exfiltration through tools, and excessive agency — and aligns to HITRUST and SOC 2. Secrets and credentials are vaulted; every agent action is scoped, logged, and revocable.

5 Regulatory, ethical & responsible AI

Use cases are **risk-classified**, and controls scale with risk. We operationalize responsible-AI principles rather than asserting them: **transparency and explainability** (every decision and action is logged with its rationale and the rule or source that drove it), **fairness and bias monitoring** across populations, **human oversight and dignity** (clinical and other consequential judgments remain human-owned), and **data minimization and purpose limitation**. Clinical-safety and privacy reviews are built into the deployment gate, and we maintain alignment with HIPAA, applicable state and federal requirements, FDA SaMD considerations where relevant, and emerging AI regulation.

6 Observability, assurance & lifecycle

We maintain **continuous telemetry** on every agent — accuracy, exception/override rate, latency, cost, and behavioral drift — backed by an **immutable, timestamped, end-to-end audit trail** of agent reasoning and actions, available to compliance on demand as a complete record rather than a sample. **Change control is absolute**: every change to a policy, rule, prompt, model, or tool is versioned, regression-tested, approved, and logged — nothing reaches production without sign-off. Incident management, periodic re-certification, retraining governance, and clean decommissioning close the lifecycle. A **rising override rate is treated as a governance signal** that automatically triggers review.

Governance as an enabler of value — not a brake

Designed this way, governance is what *allows* us to move fast and broaden autonomy responsibly. Because boundaries are explicit and enforced, because every action is observable and reversible, and because autonomy is tiered to evidence, we can **safely widen what an agent does as it earns trust** — capturing more value over time without re-opening the risk question at every step. The same controls that keep our agents safe, secure, and compliant are precisely what make it responsible to let them do more.